

(U) Committee on National Security Systems



**(U) ENTERPRISE AUDIT
MANAGEMENT (EAM) FOR
NATIONAL SECURITY SYSTEMS (NSS)**

(U) THIS DOCUMENT PRESCRIBES MINIMUM STANDARDS
(U) YOUR DEPARTMENT OR AGENCY MAY REQUIRE FURTHER
IMPLEMENTATION



NATIONAL MANAGER

FOREWORD

1. The Committee on National Security Systems Instruction (CNSSI) 1015, *Enterprise Audit Management (EAM) for National Security Systems (NSS)*, establishes responsibilities for EAM for NSS and defines the minimum national requirements for an Enterprise Audit Management program within the national security community to enable enterprise system security and comprehensive situational awareness (SA). EAM applies the general concepts, processes, and activities of audit management with a focus on outcomes that affect the security posture of the system and the enterprise.
2. This Instruction presents amplifying guidance and parameter values (PVs) that aid in the implementation of the security controls required by CNSSI-1253, Categorization and Control Selection for National Security Systems. Annex A of this Instruction contains an audit (AU) control table derived from CNSSI-1253. EAM compliance is achieved by implementing the EAM security controls in accordance with the parameters and guidance defined in Annex A.
3. It is anticipated that the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, Revision 5, Security and Privacy Controls for Information Systems and Organizations, September 2020 and CNSSI-1253 baselines will evolve as technology evolves and automation becomes more prevalent. As such, and in consideration of an ever-evolving threat landscape for NSS, this Instruction will periodically be reviewed and revised accordingly.
4. This Instruction supersedes CNSSI-1015 dated September 2013.
5. This Instruction may be obtained from the CNSS website: <https://www.cnss.gov>.

FOR THE NATIONAL MANAGER

//s//

DAVID LUBER

Deputy National Manager for National Security Systems
National Security Agency

CNSS Secretariat, C072, National Security Agency, 9800 Savage Road, STE 6747, Ft. Meade, MD 20755.
Office Phone Number: (410) 854-6805; Email: CNSS@nsa.gov

Table of Contents

FOREWORD	2
SECTION I – PURPOSE	4
SECTION II – AUTHORITY	4
SECTION III – SCOPE	4
SECTION IV – POLICY	4
SECTION V – RESPONSIBILITIES	5
SECTION VI – DEFINITIONS.....	5
SECTION VII – REFERENCES	6
ANNEX A – AU Control Guidance and Parameter Values.....	A-1
ANNEX B – Auditable Events (AU-2a).....	B-1
ANNEX C – Auditable Event Attributes (AU-3, AU-3(1))	C-1

ENTERPRISE AUDIT MANAGEMENT FOR NATIONAL SECURITY SYSTEMS

SECTION I – PURPOSE

1. Committee on National Security Systems Instruction (CNSSI) 1015 details the minimum requirements and assigns responsibilities for Enterprise Audit Management (EAM) for National Security System (NSS). This Instruction is a derivative issuance of Committee on National Security Systems Directive (CNSSD) 502, *National Directive on National Security Systems*.

SECTION II – AUTHORITY

2. The authority to issue this Instruction derives from authoritative sources that set forth cybersecurity requirements for National Security Systems (NSS) across the Federal Government. The sources include Executive Order (E.O.) 12333, *United States Intelligence Activities*; National Security Directive 42, *National Policy for the Security of National Security Systems*; and National Security Memorandum (NSM-8), *Improving the Cybersecurity of National Security, Department of Defense, and Intelligence Community Systems*.

3. Nothing in this Instruction alters or supersedes the authorities of the Director of National Intelligence.

SECTION III – SCOPE

4. This Instruction establishes the minimum EAM standards required for Department and Agencies (D/As) with NSS. It complements other CNSSIs that, when integrated across all NSS, will help organizations protect, detect, defend, and manage NSS, as well as enhance situational awareness to comply with Federal legislation and regulations, including the *Federal Information Security Modernization Act of 2014* (FISMA), the *Privacy Act of 1974* as amended (including Statutory Notes in 5 U.S.C. 552a), *Executive Order 14028*, and *National Security Memorandum 8*.

5. Upon final signature of this instruction, the control guidance and parameter values within this document will become authoritative for the applicable controls within the CNSSI-1253, *Categorization and Control Selection for National Security Systems* baselines.

SECTION IV – POLICY

6. EAM is important in securing assets, provisioning for computer network defense, and ultimately providing overall situational awareness of both the activities occurring on NSS assets and the security posture of the enterprise. Adherence to CNSSI-1015 and any subsequent standards, guidelines, and requirements promulgated by the National Manager are mandatory for all NSS.

7. Whenever conflicting CNSS requirements are encountered, this Instruction will take precedence for the implementation of EAM.

8. A mature EAM program must provide a comprehensive, automated capability optimized to protect NSS through awareness of, and the ability to manage and respond to

cybersecurity incidents and misuse of information technology (IT) and operational technology (OT) systems in both cloud-based and on-premises environments. Additionally, the EAM program must provide detection and support investigation and remediation of insider threat, the threat from remote adversaries, and the threat from non-malicious activities that can impede the mission, enablement of effective IT/OT operations and maintenance.

9. Audit information must be accessible to authorized individuals as part of their official duties with a valid need to know. Such access provides the means to accomplish several broad security and mission objectives including, but not limited to:

- a. Investigation and response to cyber incidents, due to known or suspected NSS compromise;
- b. Unique identification and accountability of individuals using IT resources;
- c. Identification of unauthorized activity from any source; and
- d. Recorded evidence of system, application, and network activity.

SECTION V – RESPONSIBILITIES

9. D/As must plan, implement, and manage automated EAM activities for their NSS in accordance with the guidance provided in this Instruction and in consultation with their respective legal counsel and civil liberties and privacy officials. D/As may also implement more stringent audit management requirements than those included in this Instruction as necessary to support their respective missions.

10. D/As must configure and implement enterprise audit capabilities to effectively protect and defend NSS; therefore, heads of D/As must implement management and technical security capabilities for EAM, as defined in Annex A.

11. The authorizing official (AO) is responsible for making risk decisions in support of EAM, using the Risk Management Framework found in CNSSP-22, *Policy on Information Assurance Risk Management for National Security Systems*, and the selection of applicable security controls in accordance with CNSSI-1253.

12. D/As must demonstrate ongoing compliance through integration of EAM with their organizational continuous monitoring efforts.

SECTION VI – DEFINITIONS

13. Definitions used in CNSSI-4009, *Committee on National Security Systems (CNSS) Glossary*, dated March 2022 (Reference h), apply to this Instruction.

SECTION VII – REFERENCES

14. The following documents are referenced or provide amplifying or supplementary information¹. Future updates to referenced documents will be considered applicable to this Instruction.

- a. Executive Order (E.O.) 12333, *United States Intelligence Activities*, 4 December 1981, as amended.
- b. Executive Order (E.O.) 14028, *Improving the Nation's Cybersecurity*, May 2021, Section 7(g)-(h) and Section 9.
- c. National Security Memorandum (NSM-8), *Improving the Cybersecurity of National Security, Department of Defense, and Intelligence Community Systems*, January 2022.
- d. National Security Directive (NSD) 42, *National Policy for the Security of National Security Telecommunication and Information Systems*, July 1990.
- e. Committee on National Security Systems Directive (CNSSD) 502, *National Directive on National Security Systems*, December 2004.
- f. Committee on National Security Systems Directive (CNSSD) 504, *Directive on Protecting National Security Systems from Insider Threat*, September 2021.
- g. CNSS Instruction (CNSSI) 1253, *Categorization and Control Selection for National Security Systems*, July 2022.
- h. CNSS Policy (CNSSP) 22, *Cybersecurity Risk Management Policy*, September 2021.
- i. Committee on National Security Systems Instruction (CNSSI) 4009, *Committee on National Security systems (CNSS) Glossary*, March 2022.
- j. National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53 Revision 5, *Security and Privacy Controls for Information Systems and Organizations*, September 2020.

¹ ICS 500-27 and OMB M-21-31 were also considered in the issuance review and update.

ANNEX A – AU CONTROL GUIDANCE AND PARAMETER VALUES

1. This Annex provides control guidance and parameter values for select AU controls derived from CNSSI-1253. This control table is baseline independent; D/As must leverage this table for the control implementation information relevant to the baseline derived from CNSSI-1253. Parameter values are provided only if appropriate at the NSS level. In cases where parameter values are not provided, D/As must define them as appropriate for their enterprise.
2. D/As must implement the relevant CNSSI-1253, Categorization and Control Selection for National Security Systems, baseline for approval by the AO. When implementation of a security control as defined in this instruction is not possible, the organization must ensure the EAM requirements are met and the controls/mitigations are approved by the AO.
3. NSS operate in an environment of ever-evolving cyber threats. Security control Parameter Values and Guidance described in this Instruction will augment CNSSI-1253 baselines to increase the accuracy and speed of cybersecurity incident alerts and provide increased situational awareness. Whenever conflicting CNSS requirements are encountered, this Instruction will take precedence for the implementation of EAM.

ID	Title	Parameter Value	Guidance
AU-1	Policy and Procedures	a. All personnel c.1., c.2. 1st PV: at least annually	AU-1a.- D/A must ensure AU policy details the responsibilities for all roles associated with enterprise audit, including identification, collection, correlation, analysis, storage and reporting of audit information. AU-1a.2 – D/A must ensure that procedures are authored that describe the implementation of all elements of the audit logging process to include generation, collection, retention, reduction, analysis, protection, and sharing functions.

ID	Title	Parameter Value	Guidance
AU-2	Event Logging	a. See Annex B: Auditable Events b. Audit Logging Standards for each technology family that implement the applicable events from AU-2a.	D/As must develop/adopt audit logging standards for each technology family that implements the applicable events from Annex B. The events must enable audit triggers and alerts to effectively audit all components of an information system (IS). Audit logging standards must be evaluated against the events from Annex B and approved for use by the AO.
AU-3	Content of Audit Records		Refer to Annex C - Auditable Event Attributes
AU-3(1)	Additional Audit Information	PV: Event attributes as defined in Annex C, plus any additional attributes defined by the audit logging standard adopted for each technology utilized.	Refer to Annex C - Auditable Event Attributes
AU-4	Audit Log Storage Capacity	PV: Log retention requirements as specified in AU-11	D/A must ensure that audit logs are not overwritten under any circumstance prior to being offloaded.
AU-4(1)	Transfer to Alternate Storage	PV: In near real-time and on an automated basis	D/A must forward all required audit logging data, in near real-time and on an automated basis, to centralized systems responsible for security, information, and event monitoring (e.g., SIEM) and bulk storage/retention, if feasible. If near real-time log forwarding is not feasible, agencies must document mitigating controls to support the confidentiality, integrity and availability of the audit logs.

ID	Title	Parameter Value	Guidance
AU-5	Response to Audit Logging Process Failures	1st PV: Designated system administrators and cyber security personnel 2nd PV: Near real time	D/A must ensure audit logging is enabled and active for system components. Ensure auditing procedures define actions to be taken in the event of a failure in any of the audit logging functions, including system/device generation, log collection, storage, or analysis mechanisms. Traps for detecting audit log stream disruption must be monitored.
AU-5(1)	Storage Capacity Warning	1st PV: Designated system administrators and cyber security personnel 2nd PV: Near real time 3rd PV: Maximum of 75%	Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-5(2)	Real-Time Alerts	1st PV: Near real time 2nd PV: Designated system administrators and cyber security personnel 3rd PV: Minimally but not limited to: - auditing software/hardware errors; - failures in the audit generation, collection, storage, or analysis mechanisms; and - audit storage capacity being reached or exceeded	D/A must ensure auditing procedures define actions to be taken in the event of a failure in any of the audit logging functions identified.

AU-6	Audit Record Review, Analysis, and Reporting	AU-6a. PV1: Not less than weekly or as required by an alarm or anomaly, or as directed by a cognizant cyber authority based on threat conditions.	D/A must ensure that auditing procedures account for the effective analysis and reporting of auditable events.
------	--	---	--

ID	Title	Parameter Value	Guidance
AU-6(1)	Automated Process Integration		D/A must implement capability to automate auditable event analysis, anomaly detection, and reporting of unusual activities. D/A must develop and implement automated hunt and incident response playbooks that define thresholds and priorities to support audit triggers and alerts, reporting requirements (e.g., timelines, recipients).
AU-6(3)	Correlate Audit Record Repositories		D/A will ensure centralized access and visibility for all audit logs at the highest-level security operations center for each D/A.
AU-6(4)	Central Review and Analysis		D/A must implement capability for centralized, integrated audit record review (e.g., Security Information and Event Management (SIEM) capability). Audit logs must be made available to enterprise security operations.
AU-6(5)	Integrated Analysis of Audit Records		Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-6(6)	Correlation with Physical Monitoring		Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-7	Audit Record Reduction and Report Generation		D/A must define cross-organizational analytics for use across agency components. This includes defining audit triggers and alerts with associated thresholds and priorities to effectively audit the organization. Note: This is a continuous process influenced by the network/user environment and changing priorities and threats.

AU-7(1)	Automatic Processing		D/A must define key searchable audit log metadata fields (e.g., date/time of events; user identifiers; IP addresses involved in the event; type of event; and event success/failure of events)
---------	----------------------	--	--

ID	Title	Parameter Value	Guidance
AU-8	Time Stamps	b. Millisecond granularity, where feasible	Timestamps must be applied consistently to logs from all computing devices, routers, switches, and servers. Agencies must maintain log timestamps in a format that meets the following requirements, based on both ISO 7 8601 and RFC 3339: Date and Time on the Internet: Timestamps. • YYYY-MM-DDThh:mm:ss.mmmZ (Zulu time, UTC+0) and • YYYY-MM-DDThh:mm:ss.mmm+04:00 (UTC+4) Software developed by D/As or by contractors on behalf of D/As must log timestamps for each event in accordance with these requirements. For any NSS software that does not produce data in this format or fidelity, D/A will transform records to conform to these standards prior to ingestion into the centralized capability (e.g., SIEM) and/or transfer to long-term storage.
AU-9	Protection of Audit Information		D/A will ensure all AU controls associated with generation, collection, review and retention are applied to audit logs and the systems processing the audit logs.

AU-9(2)	Store on Separate Physical Systems or Components	PV: In near real-time and on an automated basis	D/A must forward all required audit log data, in near real-time and on an automated basis, to centralized systems responsible for security, information, and event monitoring (refer to AU-6(4) guidance above) and bulk storage/retention, if feasible. If near real-time log forwarding is not feasible, agencies must document mitigating controls to support the confidentiality, integrity and availability of the audit logs.
---------	--	---	---

ID	Title	Parameter Value	Guidance
AU-9(3)	Cryptographic Protection		D/A will must that systems protect audit log information by cryptographic methods to prevent tampering and unauthorized access. Audit logs must be encrypted in transit between source and destination and at rest. D/A must ensure that systems leverage integrity-verification mechanisms (e.g., audit log hashing) to periodically check for unauthorized changes to audit logging configurations and log files.
AU-9(4)	Access by Subset of Privileged Users		D/A must ensure that auditing procedures account for the access controls for audit systems and data, to include requirements for access to the audit log systems and data (e.g., appointment orders, training) Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-9(5)	Dual Authorization	2 nd PV: Any audit information	Refer to NIST 800-53 Revision 5 discussion for implementation guidance.

AU-9(6)	Read-Only Access		D/A must ensure that auditing procedures account for the access controls for audit systems and data. Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-10	Non-Repudiation	PV: Auditable events identified in CNSSI 1015 Annex B and subsequently developed D/A auditing logging standards	Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-11	Audit Record Retention	The time period identified in the current National Archives and Records Administration (NARA) General Records Schedules (GRS)	D/A must define an audit record retention timeframe not less than the period identified in the current NARA GRS.

ID	Title	Parameter Value	Guidance
AU-11(1)	Long-Term Retrieval Capability	Procedures and capabilities	Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-12	Audit Record Generation	a. All information systems and network components	Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-12(1)	System-Wide and Time-Correlated Audit Trail	1 st PV: All information systems and network components 2 nd PV: Organizational tolerance defined in AU-8	Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-12(2)	Standardized Formats		D/A will ensure that all audit event data adheres to the format specified within the defined standard for their technology. Absent a standard, NSS software developed by or on behalf of D/A, the developer must implement a defined audit logging standard and document the associated audit logging schema.

AU-12(3)	Changes by Authorized Individuals	2 nd PV: All audit log generating components 3 rd PV: The threat environment, event triggers, and analysis use cases	D/A must ensure that auditing procedures account for the protection of audit systems and data, to include requirements for changes to the audit log systems and data.
AU-14	Session Audit	1 st PV: User Activity Monitoring (UAM) Personnel	Refer to NIST 800-53 Revision 5 discussion for implementation guidance.
AU-14(1)	System Start Up		D/A will ensure that UAM capability is implemented IAW CNSSD 504.
AU-14(3)	Remote Viewing and Listening		D/A will ensure that UAM capability is implemented IAW CNSSD 504.
AU-16	Cross-Organizational Audit Logging		Cross-organizational audit logging is applicable when organizations have established policies, standards, or agreements with external organizations in place that mandate cross-organizational audit logging. Refer to NIST 800-53 Revision 5 discussion for additional implementation guidance.
ID	Title	Parameter Value	Guidance
AU-16(1)	Identity Preservation		D/A will ensure that all entities (e.g., users, non-person entities) are uniquely identified within user-attributable audit logs. Refer to NIST 800-53 Revision 5 discussion for further implementation guidance.
AU-16(2)	Sharing of Audit Information	2 nd PV: Policies, standards, or organizational agreements	D/A must allow access, upon request, to logs by specified named individuals, or based on specific cyber defense mission roles. D/A will share audit information IAW established policies/standards/agreements for their operating environment.

AC-2(7)	Privileged User Accounts		Ensure that procedures are defined for the management and monitoring of Privileged User Accounts associated with all aspects of Enterprise Audit.
CP-9	System Backup	a. 2nd PV: At least weekly or as defined in the contingency plan b. At least weekly or as defined in the contingency plan c. When created, received, updated, or as defined in the contingency plan	Ensure that procedures are defined for automated back-up of audit logs, auditing systems and audit-related configurations.
SC-45(1)	Synchronization with Authoritative Time Source	a. 1st PV: At least once every 24 hours b. One second	D/A must use a GPS master station clock as a baseline reference for timestamps used for logs and systems producing logs. If GPS reference is not possible, use NIST's authenticated time service. Public, unauthenticated, and unencrypted NTP pools must only be used as an option of last resort, and only for as long as needed to begin leveraging other options.

ANNEX B – AUDITABLE EVENTS (AU-2a)

1. The following tables represent the baseline set of auditable events necessary to support enterprise audit. Not all event types are relevant across all technologies, and this annex cannot account for all possible implementations. The D/A must develop or adopt audit logging standards for all technology families within their enterprise that incorporate the applicable events from the tables below. The audit logging standards must be evaluated against the events in this annex and must be approved for use by the Authorizing Official. These standards will provide uniform implementation and assessment criteria for the audit logging function.

Account Management	<i>Account Management activities pertain to events associated with user and or system (non-person entity) accounts across all technologies (e.g., systems, applications, devices)</i>	
	Event (Target: Action)	Description
	Account: View	Examining an account or profile
	Account: Add	Creation of an account
	Account: Modify	Changing aspects/attributes of an account
	Account: Delete	Removal of an account
	Account: Lock	Temporary inactivation of an account
	Account: Unlock	Enabling an account following a temporary inactivation

Group/Role Management	<i>Group/Role Management activities pertain to events associated with groups and roles across all technologies (e.g., systems, applications, devices)</i>	
	Event (Target: Action)	Description
	Group/Role: View	Examining a group/role
	Group/Role: Add	Creation of a group/role
	Group/Role: Modify	Changing aspects/attributes of a group/role
	Group/Role: Delete	Removal of a group/role

Access Control	<i>Access Control events describe activity associated with identity verification (e.g., password, pin, certificate) and granting of access to systems and resources.</i>	
	Event (Target: Action)	Description
	Entity: Authenticate	Verification of the identity of a user, process, or device, often as a prerequisite to allowing access to resources in a system
	Entity: Logon	Presentation of a credential or token for the purpose of instantiating a new session on a system or application
	Entity: Logoff	Termination of a user session

Object / Resource Activity	<i>Object/Resource Activity events describe activity associated with an object by a user or NPE. Objects are “passive system-related entities, including devices, files, records, tables, processes, programs, and domains that contain or receive information” (NIST SP 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations). Objects should be defined in the context of the system/application/process.</i>	
	Event (Target: Action)	Description
	Object: View/Access	Read/open action on an object
	Object: Create	Generation of a new instance of an object
	Object: Delete	Erasure of an instance of an object
	Object: Modify	Change of state of an object
	Object: Restore	Recovery or return of an object to a previous state
	Object: Print	Execution of the print command. Includes Print to File, e.g., PDF
	Object: Download	Retrieval of an object from an external IS often via network connection
	Object: Export	Transmission of an object from one IS to another
	Object: Import	Transmission of an object to an IS to another
	Object: Move	Transmission of an object to/from an IS. Includes between systems and to/from external devices/media.
	Object: Upload	Transmission of an object from one IS to another, often via network connection.
	Object: Ownership Modification	Change of object ownership or assignment
	Object: Permission Modification	Change of object access permissions (e.g., access control list)

Privileged Use / Special Access	<i>Privileged Use/Special Access events describe activities performed with elevated privileges on the target information system/application.</i>	
	Event (Target: Action)	Description
	Object: Admin or root-level access	Read/open action on an object with using a privileged account or role. Includes local and remote access.
	System: Admin or root-level access	Accessing a system, application, or process with privilege account or role. Includes local and remote access.
	System: Privilege/Role Escalation	Invoking an account or role with greater privileges than the current session account

System: Audit log access	Special category of object access involving access to audit logs
System: Configuration changes	Changes to the configuration of a system, application, or process.
System: Security changes or audit policy changes	Modification of system / application security configuration or policy changes. Includes changes to Access Control Model (e.g., RBAC, MAC)

System / Application / Process	<i>System / Application / Process events describe activity associated with physical or virtual systems as well as applications and processes operating within systems.</i>	
	Event (Target: Action)	Description
	System/App/Process: Restart	A restart/reboot command was sent to the system, application or process.
	System/App/Process: Stop	The act of halting a system, application, or process.
	System/App/Process: Access	Accessing a system, application, or process. Includes local and remote access.
	System/App/Process: Installation	Deploying a system, application or process.
	System/App/Process: Start	Initiate operation of a system, application, or process
	System/App/Process: Print (to device)	Execution of a print command at the system level, as well as the act of transferring data to print form
	System/App/Process: Search/Query	Execution of a search/query function within a system, application or process

Device (Physical or Virtual)	<i>Device events describe the activities associated with physical or virtual devices (e.g., external drives, printers)</i>	
	Event (Target: Action)	Description
	Device: Access	Access to a device. Includes local and remote access.
	Device: Attach	Attaching a device to an information system
	Device: Create	Addition/installation of a device to an information system
	Device: Delete	Removal/termination of a device from an information system
	Device: Detach	Remove, release or disengage a device from an information system

	Device: Modify	Change of a device, device attributes or device configuration
	Device: Mount	Establishing a connection to a device
	Device: Unmount	Termination of a connection to a device

Network Communications	<i>Network Communication events describe the activities associated with network devices (e.g., routers, switches) as well as security devices (e.g., firewalls, Intrusion Detection/Prevention Systems)</i>	
	Event (Target: Action)	Description
	Network Connection: Open	Establishing a connection with a remote system or process over the network
	Network Connection: Close	The termination of a network connection
	Network Connection: Reset	A network connection was re-established and/or a reset message was sent
	Network Connection: Fail	Failure to establish / maintain a network connection
	Network Connection: Refuse	Rejection of a network connection. Often based on attempts to access ports that are closed or blocked by a network device or service.

ANNEX C – AUDITABLE EVENT ATTRIBUTES (AU-3, AU-3(1))

1. CNSSI-1253 selects AU-3 from NIST SP 800-53 for all NSS baselines. The control states that all information systems will generate audit records that establish:

- a. What type of event occurred;*
- b. When the event occurred;*
- c. Where the event occurred;*
- d. Source of the event;*
- e. Outcome of the event; and*
- f. Identity of any individuals, subjects, or objects/entities associated with the event.*

2. Control Enhancement AU-3(1) provides organizations the ability to specify additional attribute information in the form of organizationally defined values. This Annex provides the amplifying guidance and organizationally defined values for AU-3 and AU-3(1) for NSS. The table below provides a set of event log attributes for auditable events generated by an NSS.

3. The table below is not exhaustive in terms of possible event attributes, nor are all attributes applicable to all system types. NSS require audit logging to be contextual, consistent, and use organizational standards so that logged event data can be effectively consumed, correlated, analyzed, managed and shared as appropriate. D/As must identify a standardized set of audit log attributes for the technology and/or information system-specific audit logging standards that are developed and/or implemented for their NSS. Special focus should be given the systems and applications that provide access to sensitive information.

Attribute Category	Attribute Name	Descriptor	AU-3 Attribute
Event Information	Date/Time	YYYY-MM-DDThh:mm:ss.mmmZ (Zulu, UTC+0) or YYYY-MM-DDThh:mm:ss.mmm+04:00 (UTC+4) This format is based on both ISO 8601 and RFC 3339: Date and Time on the Internet: Timestamps. Software developed by D/As or by contractors on behalf of D/As must log timestamps for each event in accordance with these requirements. For any NSS software that does not produce data in this format or fidelity, D/A will transform records to conform to these standards prior to ingestion into the centralized capability (e.g., SIEM) and/or transfer to long-term storage.	WHEN
Event Information	Unique ID	Unique audit message ID	SOURCE

Attribute Category	Attribute Name	Descriptor	AU-3 Attribute
Event Information	Event/Action Type	Standardized type Identifier for the action	WHAT
Event Information	Action Result	Result of the action, e.g., Success, Failure, Grant, Deny	OUTCOME
Event Information	Status Code/Message	As applicable	OUTCOME
Event Information	Session/Transaction ID	e.g., Application generated session ID	SOURCE
Event Information	Security Attributes	Security markings for the event log	SOURCE
Application Metadata	Application Name	Application Name	SOURCE
Application Metadata	Application Version	Application Version	SOURCE
Application Metadata	Application Owner Agency	App Owner Agency, Organization	SOURCE
Application Metadata	Application URL	Application URL	SOURCE
Application Metadata	Application Network	Application Network	SOURCE
Application Metadata	Application Confidentiality	Highest security level/classification of the Application	SOURCE
User/Entity Information	Unique Identifier	Use globally unique identifier where feasible (e.g., Public Key Distinguished Name); Include unique ID for non-person entities (NPE) and processes	IDENTITY
User/Entity Information	Entity Metadata	Organizational Affiliation, User Citizenship, Role	IDENTITY
User/Entity Information	Source IP Address	Source address where the action originated. IPv4 and/or IPv6	IDENTITY/SOURCE
User/Entity Information	Entity Role, Type	e.g., General User, Power User, Administrator, NPE	IDENTITY

Resource Acting Upon	Type of Object	Type Identifier of the object that was the action target, e.g., file, object, user account	WHAT/IDENTITY
Resource Acting Upon	Object Metadata	Details describing the target of the action, e.g., name of object accessed, summary, classification. <i>Especially relevant to Application audit logging activity.</i>	WHAT
Resource Acting Upon	Object Location	e.g., Path, Uniform Resource Locator, external device/media location	WHAT
Resource Acting Upon	Destination IP Address	IP Address for the action target. IPv4 and/or Ipv6	IDENTITY/SOURCE
Resource Acting Upon	Hostname of Server	Server FQDN	IDENTITY/SOURCE
Attribute Category	Attribute Name	Descriptor	AU-3 Attribute
Resource Acting Upon	Device Identifier	MAC Address/unique identifier	IDENTITY/SOURCE
Resource Acting Upon	Size of Object (KB)	Size of target object in Kilobytes, as applicable	WHAT
Resource Acting Upon	Resource ID	Unique ID of the target of the action, as applicable	WHAT
Resource Acting Upon	Search Attributes	e.g., Search Type, Search Term, Search Results. <i>Especially relevant to Application audit logging activity.</i>	WHAT